

API Security Risk Analysis Report

1. Introduction

APIs are widely used in modern applications such as mobile apps, SaaS platforms, and web services. However, insecure APIs can expose sensitive data and create security risks.

This report analyzes the security of a public test API to identify potential vulnerabilities and security weaknesses.

2. API Tested

API Name: JSONPlaceholder

Base URL:

<https://jsonplaceholder.typicode.com>

Endpoints Tested:

/users

/posts

3. Tools Used

The following tools were used during the analysis:

- Postman (API testing)
- Web browser (Firefox)

4. Methodology

The API was tested using read-only GET requests through Postman. The endpoints were analyzed to check authentication requirements, response data exposure, and HTTP headers.

Only safe and ethical testing methods were used.

5. Identified Risks

Risk 1 — Unauthenticated API Access

Severity: Medium

The API endpoints were accessible without authentication. This means anyone can retrieve data without providing credentials or tokens.

Impact:

Attackers may collect large amounts of user data from the API.

Recommendation:

Implement authentication mechanisms such as API keys or OAuth tokens to restrict access.

Risk 2 — Excessive Data Exposure

Severity: Medium

The API response contains multiple user data fields including email, phone, and company information. Applications may not require all these fields.

Impact:

Unnecessary data exposure increases the risk of information misuse.

Recommendation:

Return only necessary data fields required by the application.

Risk 3 — Missing Rate Limiting

Severity: Low

No rate limiting mechanism was observed during testing. This means unlimited requests may be sent to the API.

Impact:

Attackers could send automated requests to scrape data or overload the API.

Recommendation:

Implement rate limiting to restrict the number of requests per user or IP address.

6. Conclusion

The analysis identified several potential security risks including unauthenticated access, excessive data exposure, and lack of rate limiting. Implementing proper authentication and security controls can significantly improve API security.